
Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

1/47

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"
Deliberation no. 3FR/2024 of November 20, 2024

The National Commission for Data Protection sitting in a restricted formation, composed of Ms. Tine A. Larsen, president, and Messrs. Thierry Lallemand and Marc Lemmer, commissioners;
Having regard to Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC;
Having regard to the law of August 1, 2018 on the organization of the National Commission for Data Protection;
Having regard to the internal regulations of the National Commission for Data Protection adopted by decision no. 07AD/2024 dated February 23, 2024, particularly its Article 10, paragraph 2;
Having regard to the regulation of the National Commission for Data Protection concerning the investigation procedure adopted by decision no. 08AD/2024 dated February 23, 2024, particularly its Article 9;
Considering the following:

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

2/47

I. Facts and Procedure

1.
During its deliberation session on October 7, 2022, the National Commission for Data Protection (hereinafter: the "CNPD" or the "National Commission") sitting in plenary formation decided to open an investigation into the company "A" based on Article 38 of the law of August 1, 2018 on the organization of the National Commission for Data Protection and the general regime on data protection (hereinafter: the "law of August 1, 2018") and to appoint Mr. Alain Herrmann as the head of the investigation.

2.
The said decision specified that the investigation conducted by the CNPD aimed to check the application and compliance with Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (hereinafter: the "GDPR") and the law of August 1, 2018, and "more specifically, the compliance of employee and third-party (clients, suppliers, or others) surveillance measures implemented by company A, particularly through a video surveillance system."¹

3.
Company A is a limited liability company registered in the Trade and Companies Register of Luxembourg under number [...] and has its registered office at L-[...], [...] (hereinafter: the "controlled entity"). The controlled entity has the purpose of "[retail trade of telecommunications equipment in specialized stores]."²

4.
On January 30, 2023, agents of the CNPD conducted an on-site visit to three sites operated by the controlled entity (hereinafter: the "on-site visit"):

-
Company A1, [...], L-[...] ("Site A1");

-
Company A2, [...], L-[...] ("Site A2");

-
Company A3, [...], [...], L-[...] ("Site A3").

This moment is referenced later in this decision as the "start of the investigation."

5.
By email dated February 4, 2023, the controlled entity provided the CNPD with additional information requested during the said visit.
- 1 Deliberation no. [...] of [...] of the National Commission for Data Protection concerning the opening of an investigation mission with "Company A."
- 2 Coordinated articles of the controlled entity of [...] ; document 1 of the statement of objections.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

3/47

6.
The report no. 2023-9246 concerning the on-site visit conducted on January 30, 2023, at the company A (hereinafter: the "report") prepared by the agents of the CNPD was sent to the controlled party by mail on February 10, 2023, along with a request for additional information.

It follows from this report that:

-
Site A1 and Site A2 are equipped with a video surveillance system, while Site A3 is not equipped with such a system, and all three sites operate under the commercial name "B";

-
the video surveillance system includes six cameras at Site A1 and four cameras at Site A2 (hereinafter: the "video surveillance system");

-
the video surveillance system operates continuously (24 hours a day, 7 days a week) and the captured and recorded images are stored on the central server of the controlled party located at Site A1.

7.
The controlled party, represented by Master [...], submitted written observations on the report by mail dated March 23, 2023.

8.
Subsequently, the controlled party, represented by Master [...], and the investigation service of the CNPD exchanged correspondence.

9.
At the end of its investigation, the head of the inquiry notified the controlled party on May 2, 2024, of a statement of objections (hereinafter: the "statement of objections") detailing the breaches he considered constituted in this case with respect to the requirements prescribed by Article 6.1 of the GDPR (lawfulness of processing), Articles 13.1 and 13.2 of the GDPR (right to information), Article 5.1.a) of the GDPR (principle of transparency), Articles 24.1 and 5.2 of the GDPR (obligation and principle of accountability), Article 25.2 of the GDPR (obligation of data retention limitation), and Article 32.1 of the GDPR (obligation of security of processing).

3 Report, finding 2.

4 Report, finding 5.

5 Report, finding 7.

6 See point 8 of the statement of objections for a detailed list of exchanges throughout the investigation.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

4/47

The head of the inquiry proposed to the National Commission sitting in a restricted formation (hereinafter: the "Restricted Formation") to adopt five different corrective measures, as well as to impose an administrative fine on the controlled party in the amount of 14,288 euros.

The opportunity to submit written observations on the statement of objections was offered to the controlled party.

10.

By mail dated June 21, 2024, the controlled party, represented by Master [...], submitted its observations regarding the statement of objections.

11.

On July 4, 2024, the head of the inquiry first responded to the controlled party by email regarding a preliminary question raised in its letter of June 21, 2024, and then transmitted the file to the Restricted Formation for a decision on the outcome of the investigation.

12.

The president of the Restricted Formation informed the controlled party, represented by Master [...], by mail dated July 17, 2024, that its case would be listed for the Restricted Formation session on September 18, 2024, and that it was offered the opportunity to be heard there.

13.

By email dated August 5, 2024, the controlled party confirmed its attendance at the session.

14.

During this session, the head of the inquiry, accompanied by Mr. [...], legal advisor and case manager, and the controlled party, represented by Master [...], lawyer at the Court, in the presence of Mr. [...], manager of the controlled party, Ms. [...], reception agent of the controlled party, and Mr. [...], technical assistant of the controlled party, presented their oral observations in support of their written observations and answered questions posed by the Restricted Formation. The Restricted Formation allowed the controlled party to submit additional information requested during the session within 2 weeks.

The controlled party had the last word.

15.

By email dated October 1, 2024, the controlled party provided the additional information requested to the Restricted Formation.

16.

The decision of the Restricted Formation on the outcome of the investigation will be based on:

-

the processing carried out by the controlled party taken into account by the head of the inquiry in his statement of objections; and

-

the applicable legal and regulatory provisions.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

II. In Law

II.1. On the grounds for the decision

A. On the quality of the controlled entity and the determination of the data controller

1. On the principles

17. In accordance with Article 4.7 of the GDPR, the data controller is "the natural or legal person, public authority, service, or other body which, alone or jointly with others, determines the purposes and means of the processing [...]".

18. The European Data Protection Board (hereinafter referred to as the "EDPB") has provided further explanations in its guidelines 07/2020 on the concepts of data controller and processor. It clarified that "there is no limit to the type of entity that can assume the role of data controller, but in practice, it is generally the organization itself and not an individual within it (such as the CEO, an employee, or a board member) that acts as the data controller"⁷.

2. In this case

19. The head of the investigation identified the controlled entity in point 6 of his statement of objections, clarifying that it is the company "A", and added that the controlled entity "is to be considered as the data controller, within the meaning of the GDPR, [...] regarding the video surveillance system implemented"⁸.

20. In its written observations on the statement of objections, the controlled entity expressed doubt regarding the identity of the controlled entity because it seems to have understood that the "controlled entity" would be the natural person present on the day of the on-site visit by the CNPD agents⁹.

21. The Restricted Formation wishes to clarify that the "controlled entity" is the company "A" (as specified in point 3 of this decision) and not the individual(s) present on the day of the on-site visit by the CNPD agents. The fact that the manager of the controlled entity was not present on the day of the on-site visit but that another person answered the questions posed by the CNPD agents does not change the identity of the "controlled entity". Furthermore, the fact that said person was unable to answer all the questions from the agents and/or could not respond correctly to these questions will not prejudice the controlled entity. An unannounced on-site visit is precisely not conducted in anticipation of meeting on-site the individuals responsible for data protection and/or the legal representative of the controlled entity but rather to be able to take stock of the situation.

22. It also confirms that the controlled entity is indeed the "data controller" within the meaning of Article 4.7 of the GDPR because the controlled entity determines the purposes and means of the processing, and it recalls that even if a particular natural person is designated "to ensure compliance with data protection rules, this person will not be the data controller but will act on behalf of the legal entity [...] which, in its capacity as data controller, will be ultimately responsible in the event of a breach of the rules"¹⁰.

B. On the breach related to the principle of lawfulness (Article 6.1 of the GDPR)

1. On the principles

23. In order to be legally implemented, any processing of personal data must be based on one of the legal bases exhaustively listed by the GDPR. According to Article 6.1 of the GDPR, "processing shall be lawful only if and to the extent that at least one of the following conditions is met:

- a) the data subject has consented to the processing of their personal data for one or more specific purposes;
- b) the processing is necessary for the performance of a contract to which the data subject is a party or for the performance of pre-contractual measures taken at the request of the data subject;
- c) the processing is necessary for compliance with a legal obligation to which the data controller is subject;

¹⁰ EDPB, Guidelines 07/2020 on the concepts of data controller and processor in the GDPR, Version 2.0, adopted on July 7, 2021, point 18.

no. [...] conducted with the company "A"

6/47

d) the processing is necessary to protect the vital interests of the data subject or another natural person;

e) the processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller;

f) the processing is necessary for the purposes of the legitimate interests pursued by the controller or by a third party, except where such interests are overridden by the interests or fundamental rights and freedoms of the data subject which require protection of personal data."

24. The data controller bears the burden of proof for demonstrating that the processing is lawful.

7 EDPB, Guidelines 07/2020 on the concepts of data controller and processor in the GDPR, Version 2.0, adopted on July 7, 2021, page 3.

8 Statement of objections, point 12.

9 See letter from the controlled entity dated June 21, 2024, points C) and D).

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

7/47

d) the processing is necessary for the protection of the vital interests of the data subject or another natural person;

e) the processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the data controller;

f) the processing is necessary for the purposes of the legitimate interests pursued by the data controller or by a third party, unless the interests or fundamental rights and freedoms of the data subject, which require protection of personal data, prevail, particularly when the data subject is a child. [...]

24. In its guidelines on video surveillance, the CNPD states that "within the framework of a video surveillance system, the most appropriate condition of lawfulness will generally be that of processing necessary for the legitimate interests of the data controller, unless the interests or fundamental rights and freedoms of the person(s) subject to video surveillance prevail (Article 6.1, f) of the GDPR)."¹¹

25. It should be noted that the principle of lawfulness is distinct from the principle of purpose, the latter providing that personal data must be "collected for specified, explicit, and legitimate purposes and not further processed in a manner that is incompatible with those purposes; [...] (purpose limitation)" (Article 5.1.b) of the GDPR). The processing of personal data must therefore pursue a certain predetermined objective, and it is generally not permitted to use the data collected for any purpose other than that which was defined before the processing began. It is only once the purpose of the processing, that is to say its objective, has been defined that its determined, explicit, and legitimate nature can be assessed.

2. In this case

26. During the on-site visit on January 30, 2023, CNPD agents identified a video surveillance system with 10 cameras that can be categorized into four groups¹²:

i) three cameras monitoring storage areas for IT equipment;

¹¹ See Guidelines on Video Surveillance, page 3

(<https://cnpd.public.lu/fr/dossiers-thematiques/surveillance/videosurveillance.html>).

¹² Communication of grievances, page 7, point 18.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

8/47

- ii) two cameras continuously monitoring the workstations of the employees of the controlled entity;
- iii) two cameras monitoring sales areas for phones and IT equipment; and
- iv) three cameras monitoring both sales areas for phones and IT equipment and sales counters.

27. In response to the question regarding the legal basis for the video surveillance system posed during the sending of the report¹³, the controlled entity replied by letter dated March 23, 2023, that the video surveillance system was justified "in order to ensure the protection of property and persons under its responsibility (employees/customers)"¹⁴. The response from the controlled entity thus referred to the purposes of the video surveillance system and not to its legal basis¹⁵. Upon repeated request from the head of the investigation, the controlled entity clarified that "the installed video surveillance system complies with the lawfulness condition set out in Article 6 of the GDPR and is particularly in line with points 1.a. and 1.c. of that article [...]"¹⁶. It follows that the two legal bases invoked by the controlled entity to justify the lawfulness of its processing were the consent of its employees (Article 6.1.a) of the GDPR) and compliance with a legal obligation (Article 6.1.c) of the GDPR).

28. In its communication of grievances, the head of the investigation analyzed these two legal bases and noted that, in his opinion, the two legal bases put forward by the controlled entity were "ineffective"¹⁷. Regarding the consent of the data subject, the head of the investigation held that consent cannot be freely given in a work context due to the existence of a "manifest imbalance between the data subject and the data controller"¹⁸, that is to say, between an employer and its employees. Regarding compliance with a legal obligation, he explained that in this case, the controlled entity believed that "Article L. 312-1 of the Labor Code concerning the employer's obligation of safety towards its employees"¹⁹ justified the installation of the video surveillance system.

13 Requests for additional information from the head of the investigation dated February 10, 2023, point 2a).

14 Letter from the controlled entity dated March 23, 2023, under points A) and C).

15 Letter from the CNPD dated March 31, 2023, page 2, ad (Q1).

16 Letter from the controlled entity dated May 2, 2023, ad (Q1).

17 Communication of grievances, page 13, point 46 (and point 23 in point 45 for the complete analysis).

18 Communication of grievances, page 9, point 24 and following.

19 Communication of grievances, pages 9 to 10, point 26.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

9/47

video surveillance. On the other hand, according to the head of the investigation, "for the legal basis relating to compliance with a legal obligation to be invoked to justify the implementation of a video surveillance system, the use of this means must clearly appear in the legal obligation invoked"²⁰. He specified that this was not the case in the present instance, given that the aforementioned article of the Labor Code "is not prescriptive regarding the means to be implemented to ensure compliance with this obligation and does not require the employer to resort to video surveillance"²¹.

29. Although the controlled party did not invoke the legal basis relating to legitimate interest (Article 6.1.f of the GDPR), the head of the investigation proceeded to analyze this legal basis in order to demonstrate the "intrinsic legality" of the video surveillance system²², that is to say, to demonstrate that the video surveillance system was not, from the outset, devoid of any legality, but that there was a legal basis that could, at least in part, justify the installation of said system.

His analysis shows that "the only legal basis allowing to justify - in part - [the installation of the video surveillance system] is that relating to the legitimate interests of the [controlled party] (Article 6.1.f of the GDPR)"²³. As for the three conditions that must be met to invoke legitimate interest as a legal basis²⁴, he is of the opinion that, first, there is a valid legitimate interest (i.e. the protection of property) and that, second, the necessity to process personal data for the pursued purposes is, at least partially, confirmed (with the exception of two cameras that permanently film employees at their workstations). Thirdly, he conducted a balancing exercise of interests and, according to him, the interests and fundamental rights of the individuals concerned would not prevail over a limited form of video surveillance (excluding the permanent surveillance of employees at their workstations).

30. Regarding the two cameras that permanently film the workstations of employees of the controlled party, the head of the investigation specified that these are the following cameras:

20 Statement of objections, page 10, point 27.

21 Statement of objections, page 10, point 28.

22 Statement of objections, pages 10 to 12, points 32 to 45.

23 Statement of objections, page 10, point 33.

24 Cf. Guidelines on video surveillance, page 3

(<https://cnpd.public.lu/fr/dossiers-thematiques/surveillance/videosurveillance.html>).

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

10/47

- a camera at Site A1 named "SPOT A CAM2"²⁵ which permanently films several offices of several employees (hereinafter: "camera no. 1");

- a camera at Site A2 named "SPOT B CAM6"²⁶ which permanently films the office of a specific employee (hereinafter: "camera no. 2").

He is of the opinion that camera no. 1 and camera no. 2 were not covered by the legal basis of legitimate interest because, according to him, "[s]uch permanent surveillance is considered disproportionate in relation to the pursued purposes and to the legitimate interest of the [controlled party] and constitutes an excessive intrusion into the private sphere of employees"²⁷. Thus, he concluded that by installing the two cameras devoid of legal basis, the controlled party had failed to comply with its obligation arising from Article 6.1 of the GDPR at the time of the on-site visit. Regarding the other cameras of the video surveillance system, he is of the opinion that they are necessary for the legitimate interests pursued by the controlled party and therefore covered by the legal basis of Article 6.1.f) of the GDPR.

31. The controlled party, for its part, explained that it was its employees who requested the video surveillance system²⁸ and this for several reasons. First, the controlled party had been the victim of several burglaries in the past (a police report of seizure following a break-in in April 2019²⁹ and a police search report following a burglary in April 2018³⁰ were emailed on February 4, 2023). To demonstrate that it installed the video surveillance system at the request of its employees after these burglaries, the controlled party had each of its employees sign an amendment to their employment contract confirming their agreement to the installation of the video surveillance system³¹. In response to the statement of objections, it also had each of its employees sign a testimonial declaration in which each employee answered the question "What do you think of the cameras?"³².

Furthermore, the controlled party also stated that its employees insisted on being filmed permanently in order to monitor their own movements and actions and to better

25 Cf. Statement of objections, document no. 7 and document no. 14.

26 Statement of objections, document no. 8 and document no. 18.

27 Statement of objections, page 11, point 38.

- 28 Response of the controlled party to the statement of objections dated June 21, 2024, point D.1).
29 Statement of objections, document no. 29.
30 Statement of objections, document no. 30.
31 Letter from the controlled party dated March 23, 2023, Annex 1.
32 Letter from the controlled party dated June 21, 2024, Annexes 1 and 2.
-

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

11/47

the ability to organize their work, knowing that they were working with "a multitude of high value-added parts, which, if lost, can result in the loss of the overall value of the material being repaired (thus several thousand euros)"³³. He also explained that his employees worked, for example, with magnifying glasses because they had to handle tiny parts, which posed a significant risk of loss, and that cameras helped, when necessary, employees to locate lost parts.

32. The controlled party further specified that video recordings facilitated the work of police officers after a burglary because they allowed "investigators to know where they [i.e., the burglars] placed their hands in order to find fingerprints more easily after viewing the videos"³⁴. He also stated several times that he had installed the surveillance system notably at the express recommendation of police officers³⁵ made after each burglary.

33. For the aforementioned reasons, the controlled party reiterated that, in his opinion, the legal basis of consent (Article 6.1.a of the GDPR) and the legal basis for compliance with a legal obligation (Article 6.1.c of the GDPR) were entirely applicable in this case. Regarding the legal basis of the consent of the data subject, the controlled party further added that he believes that if one always starts from the premise that there exists "an intrinsic imbalance in the relationships between an employer [...] and its employees"³⁶ that "no GDPR agreement from any employee of any company can ever be considered valid"³⁷.

Regarding the legal basis for compliance with a legal obligation, the controlled party specified that even though Article L.312-1 of the Labor Code did not expressly mention video surveillance as a means of protection, he was nonetheless of the opinion that "video surveillance [was] the only means to ensure a minimum level of security"³⁸ and met a need for enhanced protection due to "extremely violent organized gang burglaries"³⁹ and this through "the deterrent effect" of such a video surveillance system which

33 Letter from the controlled party in response to the statement of objections dated June 21, 2024, page 3, point D.1) last sentence.

34 Letter from the controlled party in response to the statement of objections dated June 21, 2024, page 6, point D.1) i).

35 Letter from the controlled party dated March 23, 2023, page 1.

36 Referring to point 25 of the statement of objections.

37 Letter from the controlled party in response to the statement of objections dated June 21, 2024, page 5, point D.1) i).

38 Letter from the controlled party in response to the statement of objections dated June 21, 2024, page 6, point D.1) i).

39 Letter from the controlled party dated March 23, 2023, page 1.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

12/47

also preserved the health of employees "in light of the anxiety-inducing effect that these events [had]

caused among most employees"⁴⁰.

34.

The Restricted Formation first recalls that there is a difference between the notion of "legal basis" provided for by Article 6.1 of the GDPR and the notion of "purpose" provided for by Article 5.1.b) of the GDPR, and that the controller has conflated these two notions on several occasions. Thus, in its response to the statement of objections, the controller maintained its assertions that, in this case, the video surveillance system was covered by three legal bases, namely "Security of property, Security of persons, Consent of employees"⁴¹, whereas only the consent of the data subjects is listed among the legally enumerated bases in Article 6.1 of the GDPR. The security of property and the security of persons may constitute legitimate interests of a data controller for which a video surveillance system may appear necessary. Thus, the appropriate legality condition would therefore be the legitimate interest according to Article 6.1.f) of the GDPR.

35.

Regarding the consent of the data subject (Article 6.1.a) of the GDPR), the Restricted Formation recalls that according to Article 4.11 of the GDPR, the consent of the data subject means, among other things, "any freely given indication of wishes." It is therefore necessary to determine whether consent can be given freely if there is an imbalance of power relations, as is the case in an employment relationship between employer and employee. The Restricted Formation does not exclude that an employer may rely on consent as a legal basis for data processing by video surveillance concerning its employees, but only in strictly exceptional situations outside of workplace monitoring (for example, for one-off processing and in a situation where the employee had a real choice and where the employer can demonstrate that the employee does not have to fear negative consequences in case of refusal; cf. the example given by the EDPB in its guidelines 5/2020 on consent under Regulation (EU) 2016/679⁴²). In the case of systematic and permanent video surveillance in the workplace, the Restricted Formation is of the opinion that employees are not able to freely give their consent and, for this reason, it finds that the legal basis of consent put forward by the controller was not valid.

40 Letter from the controller dated May 2, 2023, page 2.

41 Letter from the controller in response to the statement of objections dated June 21, 2024, page 9, point D.1) iv).

42 "23. Example 5: a film crew is going to film in an office. The employer asks for the consent of all employees working in the affected area to be filmed, as they may appear in the background of the video. Those who do not wish to be filmed are not penalized in any way, and will have equivalent offices elsewhere in the building for the duration of the filming." (EDPB Guidelines 5/2020 on consent under Regulation (EU) 2016/679, adopted on May 4, 2020, point 23)

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with company "A"

13/47

36.

Regarding the legal basis for compliance with a legal obligation (Article 6.1.c) of the GDPR), the Restricted Formation is of the opinion that the security obligation imposed on the employer towards its employees as provided in Article L. 312-1 of the Labor Code does not impose any obligation to carry out video surveillance of employees. The video surveillance system as designed in this case does not appear to be the most appropriate means to protect employees. Despite the potential deterrent effect that the video surveillance device could have, it is not primarily intended to protect employees in case of danger unless real-time viewing of the images and an appropriate intervention device were put in place. The Restricted Formation therefore concludes that the legal basis for compliance with a legal obligation was not valid.

37.

Regarding the legal basis of legitimate interest not explicitly invoked by the controlled entity but analyzed by the head of the investigation in his communication of grievances, it fully aligns with his

analysis and notes that the video surveillance device may, at least partially, rely on said legal basis. It also shares the head of investigation's view that the fundamental rights and interests of the concerned individuals (in this case: employees of the controlled entity) prevail over the legitimate interests of the controlled entity concerning camera no. 1 and camera no. 2.

In this context, it recalls that employees have the right not to be subjected to continuous and permanent surveillance in the workplace and that such permanent surveillance is considered disproportionate to the intended purpose (in this case, the security of property and the safety of individuals).

Thus, the Restricted Formation finds that the legal basis of legitimate interest (Article 6.1.f) of the GDPR was not valid concerning camera no. 1 and camera no. 2 and that consequently, the processing of personal data carried out by these two cameras was unlawful.

38.

In light of the above, the Restricted Formation aligns with the head of investigation and concludes that the controlled entity failed to comply with its obligation arising from Article 6.1 of the GDPR by installing camera no. 1 and camera no. 2, which were devoid of legal basis.

As for the measures taken by the controlled entity after the on-site visit, the Restricted Formation refers to Chapter II.2., Section 2.2. of this decision for related explanations.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with company "A"

14/47

C. On the breach related to the principle of transparency (Article 5.1.a) of the GDPR) and information obligations (Articles 13.1 and 13.2 of the GDPR)

1. On the principles

39.

Under Article 5.1.a) of the GDPR, personal data must be processed, among other things, in a transparent manner with respect to the concerned individuals (principle of transparency).

40.

The principle of transparency implies that the data controller must provide the concerned individual with a certain number of information, in accordance with Articles 12 and 13 of the GDPR.

41.

Article 13 of the GDPR provides as follows:

"1. When personal data relating to a concerned individual are collected from that individual, the data controller shall provide, at the time when the data in question are obtained, all of the following information:

a) the identity and contact details of the data controller and, where applicable, of the representative of the data controller;

b) where applicable, the contact details of the data protection officer;

c) the purposes of the processing for which the personal data are intended as well as the legal basis for the processing;

d) where the processing is based on Article 6(1)(f), the legitimate interests pursued by the data controller or by a third party;

e) the recipients or categories of recipients of the personal data, if any; and

f) where applicable, the fact that the data controller intends to carry out a transfer of personal data to a third country or to an international organization, and the existence or absence of an adequacy decision issued by the Commission or, in the case of transfers referred to in Articles 46 or 47, or Article 49(1), second subparagraph, the reference to the appropriate or suitable safeguards and the means to obtain a copy or the place where they have been made available;

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

2. In addition to the information referred to in paragraph 1, the data controller shall provide the data subject, at the time when the personal data are obtained, with the following additional information necessary to ensure fair and transparent processing:

- a) the retention period for the personal data or, where that is not possible, the criteria used to determine that period;
- b) the existence of the right to request from the data controller access to personal data, the rectification or erasure of such data, or a restriction of processing concerning the data subject, or the right to object to processing and the right to data portability;
- c) where processing is based on Article 6(1)(a) or Article 9(2)(a), the existence of the right to withdraw consent at any time, without affecting the lawfulness of processing based on consent before its withdrawal;
- d) the right to lodge a complaint with a supervisory authority;
- e) information on whether the requirement to provide personal data is a statutory or contractual requirement or if it is a condition for entering into a contract and whether the data subject is obliged to provide the personal data, as well as the possible consequences of failing to provide such data;
- f) the existence of automated decision-making, including profiling, referred to in Article 22(1) and (4), and, at least in such cases, useful information regarding the underlying logic, as well as the significance and the envisaged consequences of such processing for the data subject.

3. When the data controller intends to carry out further processing of personal data for a purpose other than that for which the personal data were collected, the data controller shall provide the data subject with information about that other purpose and any other relevant information referred to in paragraph 2 in advance.

4. Paragraphs 1, 2, and 3 shall not apply when, and to the extent that, the data subject already has such information. »

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

42.

The communication to data subjects of information relating to the processing of their data is an essential element in the context of compliance with the general obligations of transparency under the GDPR⁴³. These obligations have been clarified by the Article 29 Working Party in its guidelines on transparency under Regulation (EU) 2016/679, the revised version of which was adopted on April 11, 2018 (hereinafter: "WP 260 rev.01").

43.

It should be noted that the EDPB has adopted and approved the documents adopted by the aforementioned Group between May 25, 2016, and May 25, 2018, such as the aforementioned guidelines on transparency⁴⁴.

2. In this case

44.

During the on-site visit, the agents of the CNPD only identified a pictogram affixed to the entrance door of Site A2 indicating the existence of video surveillance and an old sticker from the CNPD referring to the number of an old authorization issued by the CNPD before the entry into force of the GDPR⁴⁵. No form of information was identified at Site A1. The person interviewed on-site by the CNPD agents could not provide further information on this matter⁴⁶.

45.

After the on-site visit, the controlled party explained to the head of the investigation that he had consulted his employees following the burglaries "to inform them of his intention to install

such a video surveillance system" and this "prior to the visit" of the CNPD agents⁴⁷ but that he had not documented these consultations. He specified that his employees had orally agreed to the installation of the video surveillance device and that it reassured them⁴⁸. He also sent the head of the investigation copies of amendments to the employment contracts of his employees (dated February 1, 2023)⁴⁹, which contained information regarding the video surveillance device and which he had made all his employees sign. He also stated that he had installed a sign containing information about the said device⁵⁰. In his letter of March 23, 2023, he claimed that "it is not disputed

43 See in particular Articles 5(1)(a) and 12 of the GDPR, see also Recital (39) of the GDPR.

44 See EDPB Decision Endorsement 1/2018 of May 25, 2018, available at:

https://www.edpb.europa.eu/sites/default/files/files/news/endorsement_of_wp29_documents_en_0.pdf

45 Statement of objections, Documents No. 27 and No. 28.

46 Cf. Minutes, finding 9.

47 Letter from the controlled party of March 23, 2023, points A) and C); Cf. Statement of objections, Document No. 3.

48 Letter from the controlled party of May 2, 2023, point (Q6); Cf. Statement of objections, Document No. 22, page 3.

49 Letter from the controlled party of March 23, 2023, Annex 1; Cf. Statement of objections, Document No. 3, Annex 1.

50 Letter from the controlled party of March 23, 2023, Annex 2. Cf. Statement of objections, Document No. 3, Annex 2.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with company "A"

17/47

that "adequate signage was not installed during the visit," but that he had "ensured to regularize the situation."

46. In the statement of objections, the head of the investigation noted that "in addition to the fact that these explanations [note: the explanations in the two letters from the controlled entity mentioned previously] only concern the employees of the Controlled (whereas the persons concerned by the Processing also include the clients and suppliers of the Controlled), the facts taken into account [...] are the facts and elements existing on the day of the on-site visit [...]". Thus, he concluded that the controlled entity failed to fulfill its obligation to inform the persons concerned according to Articles 13.1 and 13.2 of the GDPR. He also noted a violation of Article 5.1.a) of the GDPR and therefore of the principle of transparency itself because, in his view, the persons concerned were completely unaware of the various characteristics of the video surveillance system.

47. The Restricted Formation wishes to emphasize that Article 13 of the GDPR refers to the obligation imposed on the data controller to "provide" all the information mentioned therein. The word "provide" is crucial in this case and it "means that the data controller must take concrete measures to provide the information in question to the person concerned or to actively direct the person concerned to the location of said information (for example, through a direct link, a QR code, etc.)."

48. It further considers that a multi-level approach to communicating information about transparency to the persons concerned can be used in an offline or non-digital context, that is, in a real environment such as personal data collected through a video surveillance system. The first level of information (warning sign, information note, etc.) should generally include the most essential information, namely the details of the purpose of the processing, the identity of the data controller, the existence of the rights of the persons concerned, the information having the greatest impact on the processing or any processing likely to surprise the persons concerned, as well as a reference to the more detailed information of the second level (for example, via a QR code or a website address). The second level of information, that is, all the information required under Article 13 of the GDPR, could be provided or made available by other means, such as a copy of the privacy policy sent by email to employees.

49. Regarding the first level of information, the Restricted Formation notes that on the sticker affixed to the entrance door of Site A2 on the day of the on-site visit, there was only a camera and the words "VIDEO SURVEILLANCE." Affixed to the same door was also an old sticker issued by the CNPD. The Restricted Formation wishes to clarify that its stickers were issued under the previous authorization regime of the amended law of August 2, 2002, concerning the protection of individuals with regard to the processing of personal data, which was repealed by the law of August 1, 2018. These stickers have become obsolete and since the application of the GDPR, other rules in this area are applicable. Therefore, it concludes that on the day of the on-site visit, the controlled entity had not provided the information required under Article 13 of the GDPR and not even the elements required by the first level of information, and this neither to its employees nor to third parties (i.e., clients, suppliers, service providers, and visitors of the controlled entity). It notes that on March 23, 2023, therefore after receiving the report, the controlled entity sent the following documentation to the head of the investigation:

i) a copy of all amendments to the employment contracts of its employees (hereinafter: "the amendment to the employment contract"); and

ii) a photo of new signage that has been put in place (hereinafter: "the new signage").

It notes that the amendment to the employment contract contains certain first-level information but that it lacks, for example, the existence of the rights of the persons concerned or the reference to the more detailed information of the second level, and it observes that this document seems to have been drafted rather for the purpose of complying with the information provided in

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with company "A"

18/47

the GDPR.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with company "A"

19/47

Article L.261-1 paragraph (2) of the Labor Code (and not to comply with the transparency obligations set out in the GDPR). The same applies to the new signage which contains certain first-level information, but is missing, for example, the purpose of the processing, the existence of the rights of the data subjects, or the reference to more detailed second-level information. After a question posed by the Restricted Formation during the session on September 18, 2024, the controlled party stated that the new signage was only installed at the entrance of Site A1 and that they had forgotten to install it at Site A2 as well.

50. Regarding the second level of information, the Restricted Formation notes that it was non-existent until the sending of the communication of grievances.

51. Given that on the day of the on-site visit, the controlled party did not provide either a first or second level of information to the data subjects (cf. points 49 and 50 of this decision), they were unable to determine in advance the scope and consequences of the processing carried out by the video surveillance system. Consequently, they were completely unable to exercise their rights provided for in Chapter III of the GDPR. Thus, it is also appropriate to recognize a violation of the principle of transparency itself as provided for by Article 5.1.a) of the GDPR.

52. In light of the above, the Restricted Formation aligns with the opinion of the head of investigation and concludes that a non-compliance with Article 5.1.a) related to Articles 13.1 and 13.2 of the GDPR was established on the day of the on-site visit by the agents of the CNPD.

53. As for the measures taken by the controlled party after the on-site visit, the Restricted Formation refers to Chapter II.2., Section 2.2. of this decision for the relevant explanations.

D. On the breach related to the principle and obligation of accountability (Articles 5.2 and 24.1 of the GDPR)

1. On the principles

54. Under Article 5.2 of the GDPR, the controlled party, in its capacity as data controller, is required to comply with the principles of data protection (established in Article 5.1 of the GDPR) and must be able to demonstrate that these principles are respected (principle of accountability).

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with company "A"

20/47

55. Article 24.1 states that the controlled party, still in its capacity as data controller, must implement "appropriate technical and organizational measures to ensure and be able to demonstrate that the processing is carried out in accordance with the [GDPR]."

2. In this case

56. According to the head of investigation, the fact that the controlled party could not name a legal basis under Article 6.1 of the GDPR for the processing carried out by its video surveillance system and that it did not comply with its information obligations required by Article 13 of the GDPR meant, on the one hand, that the controlled party was not able to demonstrate its compliance with the principles of data protection (Article 5.2 of the GDPR) and, on the other hand, that the controlled party had not implemented appropriate organizational measures to ensure, in particular, that the processing carried out by its video surveillance system was compliant with the GDPR (Article 24.1 of the GDPR). Therefore, a non-compliance with Articles 5.2 and 24.1 of the GDPR was established.

57. The Restricted Formation recalls the paradigm shift introduced by the GDPR from a prior authorization system to a system that holds the data controller directly accountable by requiring them to prove through adequate documentation that the processing carried out is compliant with the principles of the GDPR, at the risk of an ex post control by the CNPD. Thus, Article 24.1 of the GDPR imposes on the data controller the obligation to implement appropriate technical and organizational measures, taking into account the nature, scope, context, and purposes of the processing as well as the risks, the degree of probability and severity of which varies, for the rights and freedoms of the data subjects, to ensure that the processing is compliant with the GDPR. This article is intrinsically linked to Article 5.2 of the GDPR according to which the data controller must be able to demonstrate that the principles set out in Article 5.1 of the GDPR are respected (including, in particular, the principle of transparency according to Article 5.1.a) of the GDPR). Article 24.2 of the GDPR further specifies that when proportionate to the processing activities, the measures referred to in Article 24.1 of the GDPR include the implementation of appropriate data protection policies by the data controller.

58. Since the Restricted Formation previously established that the documentation, which could have proven the compliance of the video surveillance system with the GDPR, was non-existent at the time of the on-site visit (both in relation to the legal basis...

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

21/47

legal of the said device⁶¹ that in relation to the principle of transparency and the information obligations⁶²) it aligns with the opinion of the head of the investigation and concludes that a non-compliance with Article 5.2 related to Article 24.1 of the GDPR was established on the day of the

on-site visit by the agents of the CNPD.

E. On the breach related to the principle of data retention limitation (Article 5.1.e) of the GDPR) and the obligation of data protection by default (Article 25.2 of the GDPR)

1. On the principles

59.

Article 5.1.e) of the GDPR provides for the principle of data retention limitation and states the following:

“1. Personal data must be: [...]

e) kept in a form which permits identification of the data subjects for no longer than is necessary for the purposes for which the data are processed; personal data may be stored for longer periods insofar as they will be processed solely for archiving purposes in the public interest, for scientific or historical research, or for statistical purposes in accordance with Article 89(1), provided that the appropriate technical and organizational measures required by this Regulation are implemented to safeguard the rights and freedoms of the data subject (data retention limitation);.”

60.

According to Recital (39) of the GDPR “personal data should be adequate, relevant and limited to what is necessary for the purposes for which they are processed. This requires, in particular, ensuring that the duration of data retention is limited to the strict minimum. Personal data should only be processed if the purpose of the processing cannot be reasonably achieved by other means. To ensure that data is not kept longer than necessary, deadlines should be set by the data controller for their deletion or for periodic review [...].”

61.

Article 25 of the GDPR introduces two general obligations for the data controller and/or the processor, namely data protection by design (Article 25.1 of the GDPR) and data protection by default (Article 25.2 of the GDPR). Article 25.2 states more specifically:

“2. The data controller shall implement appropriate technical and organizational measures to ensure that, by default, only personal data which are necessary for each specific purpose of the processing are processed. This applies to the amount of personal data collected, the extent of their processing, their retention period, and their accessibility. In particular, these measures ensure that, by default, personal data is not made accessible to an indefinite number of natural persons without the intervention of the data subject.”

62.

In its Guidelines 4/2019 on Article 25 of the GDPR⁶³, the EDPS specifies that “[i]n its common definition in computing, the term ‘by default’ refers to the pre-existing or pre-selected value of a configurable parameter that is assigned to a software application, computer program, or computing device. These parameters are also referred to as ‘presets’ or ‘factory settings’, particularly for electronic devices”⁶⁴.

The EDPS further clarifies that “the term ‘by default’, in the context of personal data processing, refers to making choices regarding the configuration values or processing options defined or prescribed in a processing system, such as a software application, service, or device, or a manual processing procedure, which affect the amount of personal data collected, the extent of their processing, the duration of their retention, as well as their accessibility”⁶⁵.

To ensure that only personal data which are necessary for each specific purpose of the processing are processed, the EDPS emphasizes that “the fundamental requirement is that data protection is integrated by default into the processing”⁶⁶.

⁶³ Guidelines of the EDPS 4/2019 on Article 25, Data Protection by Design and Data Protection by Default, Version 2.0, adopted on October 20, 2020.

⁶⁴ Guidelines of the EDPS 4/2019 on Article 25, Data Protection by Design and Data Protection by Default, Version 2.0, adopted on October 20, 2020, point 40.

⁶⁵ Guidelines of the EDPS 4/2019 on Article 25, Data Protection by Design and Data Protection by Default, Version 2.0, adopted on October 20, 2020, point 41.

⁶⁶ Guidelines of the EDPS 4/2019 on Article 25, Data Protection by Design and Data Protection by Default, Version 2.0, adopted on October 20, 2020, point 42.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

22/47

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

23/47

2. In this case

63.

It emerges from the position taken by the controlled party after receiving the minutes that the purposes of the video surveillance system were the protection of property, the protection of individuals, and the monitoring of "the handling by its employees of high-value electronic components."⁶⁷

64.

During the on-site visit, the agents of the CNPD noted that the video surveillance system was equipped with a recording function and that the oldest video recordings dated back to December 1, 2022, meaning that these images were retained for 61 days as of the date of the on-site visit.⁶⁸

65.

The head of the investigation therefore concluded that "a duration of 61 days is largely disproportionate in view of the purpose" of the processing and that "a break-in or theft could be detected shortly for a reasonably diligent company."⁶⁹ He also specified that the CNPD's guidelines on video surveillance⁷⁰ established that video surveillance images "may be retained in principle for up to 8 days or, exceptionally, for a duration of 30 days if reasons justifying such a duration are indicated in the processing register."⁷¹ Consequently, he deemed that non-compliance with Article 25.2 was established as of the date of the on-site visit.

66.

The Restricted Formation notes that the video surveillance system pursued at least two purposes, namely the protection of property and the protection of individuals. It recalls that it is the responsibility of the data controller to determine, based on each specific purpose, an appropriate and necessary retention period to achieve that purpose. Thus, as the video surveillance system pursued multiple purposes, the retention periods must be individualized for each specific purpose.

67.

In this case, it appears from the minutes that the retention period for the oldest video recordings was 61 days.⁷² Consequently, the Restricted Formation holds that the controlled party did not determine a retention period for each purpose and that the general retention period of 61 days was disproportionate in relation to the purposes. This general retention period was therefore not compliant with the provisions of Article 5.1.e) of the GDPR.

68.

Regarding the grievance under Article 25.2 of the GDPR retained by the head of the investigation in his communication of grievances, the Restricted Formation is of the opinion that it does not possess sufficient technical details on the specific settings of the video surveillance system to conclude that the principle of data protection by default as such was not respected. It follows that it is unable to establish a breach of the obligation of data protection by default under Article 25.2 of the GDPR.

69.

In light of the above, the Restricted Formation concludes that non-compliance with Article 5.1.e) of the GDPR was established as of the date of the on-site visit by the agents of the CNPD.

70.

As for the measures taken by the controlled party after the on-site visit, the Restricted Formation refers to Chapter II.2., Section 2.2. of this decision for the relevant explanations.

F. On the breach related to the security of processing (Article 32.1 of the GDPR)

1. On the principles

71.

Under the security of processing, Article 32.1 provides as follows: "Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing as well as the risks, the likelihood and severity of which vary, for the rights and freedoms of natural persons, the data controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, including, among other things, as necessary:

- a) the pseudonymization and encryption of personal data;
- b) means to ensure the confidentiality, integrity, availability, and resilience of processing systems and services;
- e) means to restore the availability of personal data and access to it in a timely manner in the event of a physical or technical incident;

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

24/47

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

25/47

d) a procedure aimed at regularly testing, analyzing, and evaluating the effectiveness of technical and organizational measures to ensure the security of processing."

2. In this case

72. It appears from the minutes that the images captured by the video surveillance device were accessible from a control monitor installed in an unlocked office at Site A1 (hereinafter: the "monitor A1"). This office was separated from the commercial premises of this site but accessible to all employees of the controlled entity working on-site, and "the passage to the storage room located in the basement of Site A1 [was] only possible by crossing said office." Once one of the three individuals with access to the software logged in at the beginning of the morning, the images were visible in real-time and continuously throughout the working day to all employees on monitor A1. This access to the software was notably secured "by means of a combination of username and password known to three employees." By letter dated March 23, 2023, the controlled entity added that the images from the video surveillance device were also accessible remotely "via a virtual private network, more commonly known as 'VPN,' which indeed allows connecting an isolated workstation or a remote network to a local network."

73. According to the head of the investigation, access to monitor A1 had to, on the one hand, be secured "by means of individualized user accounts and passwords in order to ensure traceability of access and the association of actions, such as for example the deletion or modification of video recordings, to a clearly identifiable person," and this was not the case since there was only one user account and one password for the three employees authorized to open the software. On the other hand, he noted that access to monitor A1 also had to be secured physically so that viewing the recordings from the video surveillance device was only possible by the employees who were part of the three authorized employees. In this case, physical access to monitor A1 (once the connection was established in the morning by one of the three authorized employees) was open to all employees passing through this office, which was, moreover, a passageway to the storage room of the controlled entity.

74. The Restricted Formation can only agree with the conclusions of the head of the investigation and determine that the controlled entity, in order to comply with the requirements of Article 32.1 of the

GDPR, must create individualized access to the software accessible via monitor A1; otherwise, the traceability of access to the software cannot be guaranteed, as demonstrated by the controlled entity itself in its letter of May 2, 2023, which included the "listing of log records." This list did not allow determining which individual performed which action and from which network (via monitor A1 or via remote access). It also shares the opinion of the head of the investigation that the controlled entity must also secure physical access to the office where this monitor is located and therefore strictly restrict the possibility of viewing video recordings to authorized persons.

75. In light of the above, the Restricted Formation concludes that a non-compliance with Article 32.1 was established on the day of the on-site visit by the agents of the CNPD.

76. Regarding the measures taken by the controlled entity after the on-site visit, the Restricted Formation refers to Chapter II.2., Section 2.2. of this decision for related explanations.

II.2. On the administrative fine and corrective measures

1. On the principles

77. In accordance with Article 12 of the law of August 1, 2018, the National Commission has the powers provided for in Article 58.2 of the GDPR:

- "a) warn a data controller or a processor that the intended processing operations are likely to violate the provisions of this regulation;
- b) reprimand a data controller or a processor when the processing operations have resulted in a violation of the provisions of this regulation;
- c) order the data controller or the processor to comply with requests made by the data subject in order to exercise their rights under this regulation;

78. Communication of grievances, point 71.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

26/47

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

27/47

- d) order the data controller or the processor to bring the processing operations into compliance with the provisions of this regulation, where appropriate, in a specific manner and within a determined timeframe;
- e) order the data controller to communicate to the data subject a personal data breach;
- f) impose a temporary or definitive limitation, including a prohibition, on processing;
- g) order the rectification or erasure of personal data or the limitation of processing in accordance with Articles 16, 17, and 18 and the notification of these measures to the recipients to whom the personal data have been disclosed in accordance with Article 17, paragraph 2, and Article 19;
- h) withdraw a certification or order the certification body to withdraw a certification issued under Articles 42 and 43, or order the certification body not to issue a certification if the applicable certification requirements are not or are no longer met;
- i) impose an administrative fine in accordance with Article 83, in addition to or instead of the measures referred to in this paragraph, depending on the specific characteristics of each case;
- j) order the suspension of data flows addressed to a recipient located in a third country or to an international organization.

78.

In accordance with Article 48 of the law of August 1, 2018, the CNPD may impose

administrative fines as provided for in Article 83 of the GDPR, except against the State or municipalities.

79.

Article 83.1 of the GDPR provides that each supervisory authority ensures that the administrative fines imposed are, in each case, effective, proportionate, and dissuasive.

80.

Article 83.2 specifies the criteria that must be taken into account to decide whether to impose an administrative fine and to determine the amount of that fine:

“a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing concerned, as well as the number of affected data subjects and the level of damage they have suffered;

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

28/47

- b) whether the infringement was committed intentionally or negligently;
- c) any measures taken by the data controller or the processor to mitigate the damage suffered by the data subjects;
- d) the degree of responsibility of the data controller or the processor, taking into account the technical and organizational measures they have implemented in accordance with Articles 25 and 32;
- e) any relevant previous infringements committed by the data controller or the processor;
- f) the degree of cooperation established with the supervisory authority in order to remedy the infringement and mitigate any possible negative effects;
- g) the categories of personal data affected by the infringement;
- h) how the supervisory authority became aware of the infringement, including whether, and to what extent, the data controller or the processor notified the infringement;
- i) where measures referred to in Article 58, paragraph 2, have previously been ordered against the data controller or the processor concerned for the same subject matter, compliance with those measures;
- j) the application of approved codes of conduct in accordance with Article 40 or approved certification mechanisms in accordance with Article 42; and
- k) any other aggravating or mitigating circumstances applicable to the circumstances of the case, such as the financial benefits gained or the losses avoided, directly or indirectly, as a result of the infringement.”

81.

The imposition of administrative fines has been clarified by the Article 29 Working Party in its “Guidelines on the application and setting of administrative fines for the purposes of Regulation (EU) 2016/679” (WP 253) adopted on October 3, 2017 (hereinafter: the “Guidelines on the application and setting of fines”). These guidelines have been approved by the EDPS⁷⁹.

79 EDPS, Decision “Endorsement 1/2018” of May 25, 2018.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

29/47

82.

The Restricted Formation emphasizes that the Guidelines on the application and imposition of fines have been supplemented by the "Guidelines 04/2022 on the calculation of administrative fines under the GDPR" from the EDPB, the version 2.1 of which was adopted

on May 24, 2023 (hereinafter: the "Guidelines on the calculation of fines"). These guidelines specify a method that supervisory authorities may apply to calculate administrative fines in light of the circumstances of each specific case. This method consists of five steps⁸⁰. However, supervisory authorities are not required to apply all the steps if they are not relevant in a given case, nor to provide justifications regarding aspects of the guidelines that are not applicable⁸¹.

83.

The Restricted Formation wishes to clarify that the facts and elements taken into account in the context of this decision are those existing at the beginning of the investigation, as subsequently commented on by the controller. Any modifications made by the controller during the investigation and before the decision of the Restricted Formation, even if they fully or partially establish compliance, do not retroactively annul an established infringement (cf. Administrative Court, judgment of May 14, 2024, No. 46401 of the roll, ECLI:LU:TADM:2024:46401, p.26/27).

84.

Nevertheless, the actions taken by the controller to comply with the GDPR during the investigation procedure, or to remedy the infringements identified by the head of the investigation in the statement of objections, may be taken into account by the Restricted Formation in the context of any corrective measures to be imposed and/or any administrative fine to be imposed.

2. In this case

2.1. Regarding the imposition of an administrative fine

85.

In the statement of objections, the head of the investigation proposed to the Restricted Formation to impose an administrative fine of 14,288 euros⁸² against the controller.

80 Guidelines on the calculation of fines, page 3; for an overview of the method, see point 17 of the guidelines.

81 Guidelines on the calculation of fines, point 6.

82 Statement of objections, point 110.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

30/47

86.

The controller, in its written observations in response to the statement of objections, argued that, based on the circumstances of the case, no fine should be imposed on it⁸³.

In support of its arguments, it claimed, among other things, that the proposed fine would not be proportionate within the meaning of Article 83.1 of the GDPR because the controller would be "a small business with low added value with a large difference between turnover and profit" and that "SMEs [should be] supported and not 'crushed' by additional financial burdens." It opined that "the administrative burden [would be] already disproportionate compared to the production that a business can make" and this "especially when it comes to SMEs that [would be] at the stage of having to delegate one (or even several) persons to address non-profitable data protection issues, as opposed to large companies that [would have] the means to organize themselves." It also recalled the "dangerousness" of their activity (given that it had been a victim of several "violent" burglaries in the past) and the testimonial statements from its employees indicating that they felt more secure due to the presence of the video surveillance system⁸⁴.

87.

During the session of the Restricted Formation on September 18, 2024, the controller again requested that no administrative fine be imposed on it. In particular, it insisted that the calculation of a fine based on turnover would not be fair because there would often be "a large difference between the turnover and the net result of a small business," and it explained that, in its view, all the corrective measures proposed by the head of the investigation would have already been implemented and that the fine

should therefore be of a symbolic nature.

88.

The Restricted Formation wishes to clarify that it has taken note of all comments regarding the imposition of an administrative fine, mainly contained in the controller's position on the statement of objections. It will focus below on the analysis of the facts that are necessary to decide whether an administrative fine should be imposed and to determine, if applicable, the amount of the administrative fine in light of the criteria set out in Article 83 of the GDPR. The Restricted Formation will apply in this context the method consisting of five steps specified in the Guidelines on the calculation of fines.

83 Cf. Letter from the controller dated June 21, 2024 and, in particular, the last two pages (pages 15 to 16).

84 Cf. Letter from the controller dated June 21, 2024 and, in particular, the last two pages (pages 15 to 16).

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with company "A"

31/47

2.1.1. Step 1: Identify the processing operations in this case

89.

In accordance with the Guidelines on the calculation of fines, it is essential that the supervisory authority first determines whether one or more behaviors of the controlled entity are subject to sanctions and whether these give rise to one or more violations attributable to the controlled entity, taking into account the circumstances of the case⁸⁵.

90.

The said guidelines specify that when evaluating the same processing operation or related processing operations, the supervisory authority may take into account, as part of its assessment of violations, all legal obligations necessary for the processing operations to be carried out in compliance with the law, including, for example, obligations regarding transparency (for example, Article 13 of the GDPR)⁸⁶.

91.

In this case, the controlled entity is to be considered as the data controller within the meaning of the GDPR for the processing of personal data carried out by its video surveillance system (see point 22 of this decision). The processing of personal data carried out by this video surveillance system constitutes a set of processing operations that are carried out within a unified intention and are closely linked in terms of context, space, and time. In this instance, it is therefore considered that it is a matter of sanctioning a single behavior within the meaning of Chapter 3.1 of the Guidelines on the calculation of fines.

2.1.2. Step 2: Establish the starting amount for the subsequent calculation of the fine

92.

In accordance with the Guidelines on the calculation of fines, the supervisory authority must, secondly, establish the starting amount for the subsequent calculation of the fine, taking into account the circumstances of the case⁸⁷ and based on the assessment of three elements:

- the classification of the violations under Article 83.4 to 6 of the GDPR;
- the severity of the violation; and
- the turnover of the company⁸⁸.

85 Guidelines on the calculation of fines, Chapter 3; point 25 et seq.

86 Guidelines on the calculation of fines, point 27.

87 Guidelines on the calculation of fines, Chapter 4.

88 Guidelines on the calculation of fines, point 48.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with company "A"

32/47

2.1.2.1. The classification of violations under Article 83.4 to 6 of the GDPR

93.

Regarding the classification of violations, the GDPR provides for two categories, namely violations punishable under Article 83.4 of the GDPR and violations punishable under Articles 83.5 and 6 of the GDPR. Concerning the first category of violations, the maximum amount of the fine that can be imposed is 10 million euros or 2% of the annual turnover of the company, whichever is higher.

Regarding the second category of violations, the maximum amount of the fine that can be imposed is 20 million euros or 4% of the annual turnover of the company, whichever is higher.

94.

Through this categorization, the European legislator has provided a first (abstract) indication of the severity of the violation. Indeed, the more serious the violation, the higher the fine is likely to be.

95.

The Restricted Formation notes that several of the breaches attributed to the controlled entity, notably the breaches of Articles 6.1, 5.1.a) related to Articles 13.1 and 13.2, 5.2, and 5.1.e) of the GDPR, are classified under the provision of Article 83.5 of the GDPR, meaning that these breaches belong to the second category of violations and are therefore more serious violations.

2.1.2.2. The severity of the violation

96.

Regarding the determination of the severity of the violation, it is necessary to examine the nature, gravity, and duration of the violations (Article 83.2.a) of the GDPR), as well as their deliberate or negligent character (Article 83.2.b) of the GDPR) and the categories of personal data concerned by the violation (Article 83.2.g) of the GDPR).

97.

As for the nature of the violations (Article 83.2.a) of the GDPR), the Restricted Formation finds

-

concerning the breach of Article 6.1 of the GDPR, that it constitutes a breach of a fundamental principle of the GDPR (and of data protection law in general), namely the principle of lawfulness enshrined in Chapter II "Principles" of the GDPR;

89 Guidelines on the calculation of fines, points 49 and 50.

90 Guidelines on the calculation of fines, point 51 et seq.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with company "A"

33/47

-

regarding the breach of Article 5.1.a) related to Articles 13.1 and 13.2 of the GDPR, that the information and transparency regarding the processing of personal data are essential obligations imposed on data controllers, so that individuals are fully aware of how their personal data will be used once collected. A breach of Article 13 of the GDPR thus constitutes an infringement of the rights of the data subjects (cf. Chapter III "Rights of the Data Subject" of the GDPR) and a breach of Article 5.1.a) thus constitutes a breach of a fundamental principle of the GDPR (and of data protection law in general), namely the principle of transparency enshrined in Chapter II "Principles" of the GDPR. The principle of transparency and especially the right to information that is an integral part of it have also been strengthened under the GDPR, which reflects their particular importance;

-

regarding the breach of Article 5.2 related to Article 24.1, that the principle of accountability as stated in

Article 5.2 of the GDPR and elaborated in Article 24 is one of the cornerstones of the GDPR and reflects the paradigm shift brought about by the GDPR, namely the transition from a regime based on notifications and prior authorizations by the CNPD to greater accountability and responsibility of the data controller;

-

regarding the breach of Article 5.1.e) of the GDPR, that it constitutes a breach of a fundamental principle of the GDPR (and of data protection law in general), namely the principle of data retention limitation enshrined in Chapter II "Principles" of the GDPR;

-

regarding the breach of Article 32.1 of the GDPR, that the European legislator intended to strengthen the obligations of data controllers regarding the security of processing with this provision by requiring them to implement the minimum necessary requirements to "ensure an appropriate level of security, including confidentiality, taking into account the state of the art and the costs of implementation in relation to the risks and the nature of the personal data to be protected."⁹¹

91 Cf. Recital (83) of the GDPR.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with company "A"

34/47

98.

Regarding the severity of the violation (Article 83.2.a) of the GDPR), the Restricted Formation takes into account the purpose of the processing, the number of affected data subjects, and the level of harm they have suffered.

99.

Concerning the purpose of the processing carried out by the video surveillance system, it notes that said processing is ancillary to the main activity of the controlled entity but does not in any way form an integral part of its business model.

100.

Regarding the number of affected data subjects, the controlled entity confirmed during the session on September 18, 2024, that it concerns its [...] employees and an indeterminate number of third parties (i.e., clients, suppliers, service providers, and visitors of the controlled entity).

101.

Regarding the level of harm suffered by the affected data subjects, Recital (75) of the GDPR specifies that it is not only about physical and material damages but also about moral harm. Furthermore, the guidelines of the EDPB⁹² specify that supervisory authorities must take into account the harm suffered or likely to be suffered, although judicial authorities are competent to identify the different forms of individual harm and grant compensation.

It considers that the harm is significant for the employees of the controlled entity regarding the two unlawfully operated cameras (breach of the principle of lawfulness, points 34 to 38 of this decision). It also considers that the data subjects have suffered harm in that the controlled entity has prevented them from exercising control over their personal data by ignoring the principle of transparency and the information obligations, so that the breach found in Article 5.1.a) related to Articles 13.1 and 13.2 of the GDPR (cf. points 47 to 53 of this decision) is likely to have caused harm to the data subjects.

102.

Regarding the criterion of the duration of the violations (Article 83.2.a) of the GDPR), the Restricted Formation notes that since the GDPR came into effect in May 2018, the duration of the violations as of the on-site visit on January 30, 2023, was at least 4 years and 8 months.

103.

Regarding the question of whether the violations were committed intentionally or negligently (Article 83.2.b) of the GDPR), the Restricted Formation recalls that an administrative fine under Article 83 of the GDPR can only be imposed if it is

92 Guidelines on the application and setting of fines, page 11 and Guidelines on the calculation of fines, point 53.b)v).

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

35/47

established that the data controller has committed, either deliberately or through negligence, a violation referred to in paragraphs (4) and (6) of this article⁹³.

104.

"Intent," meaning an offense committed deliberately, encompasses both knowledge and will in relation to the characteristics of an offense, while "non-deliberately" (through negligence) means that there was no intention to commit the violation, although the data controller or the processor did not fulfill the duty of care incumbent upon them under the legislation⁹⁴.

105.

The Restricted Formation considers that the controlled party could not ignore the existence of the violated obligations⁹⁵. It aligns with the investigation leader who stated that "[f]or example, regarding the monitoring of permanent workstations and the absence of any form of information for the concerned individuals, the [c]ontrolled party could not ignore that it was appropriate to question the legality of the [s]urveillance system nor assume that it was unnecessary to inform the concerned individuals in detail about the various aspects of the [p]rocessing"⁹⁶.

106.

Furthermore, in 2015, therefore before the entry into force of the GDPR, the controlled party had requested authorization from the CNPD for its surveillance system, and the CNPD had already specified in this authorization no. [...] that "the camera filming the checkout area must be configured so that employees present behind the checkout are not targeted, by directing its field of vision towards the checkout itself and the front of the counter, that is to say, the waiting area of the customers in front of the counter" and that "the cameras must not be used to observe the performance and behavior of the staff members of the applicant outside the purposes on which this authorization is based" and that it made the controlled party "aware of the obligation to inform the concerned individuals of the implementation of the surveillance [...] by appropriate means such as display panels or pictograms."

93 In a ruling dated December 5, 2023, the CJEU (Grand Chamber) ruled that an administrative fine under Article 83 of the GDPR can be imposed "only if it is established that the data controller, who is both a legal entity and a business, has committed, either deliberately or through negligence, a violation referred to in paragraphs 4 to 6 of this article." In this regard, the CJEU specified "that a data controller can be sanctioned for behavior falling within the scope of the GDPR as long as this data controller could not ignore the unlawful nature of their behavior, whether or not they were aware of violating the provisions of the GDPR [...]" (Rulings of December 5, 2023 (Grand Chamber), *Deutsche Wohnen*, C-807/21, ECLI:EU:C:2023:950, paragraph 76).

94 Guidelines on the application and setting of fines, pages 11 to 12.

95 Rulings of December 5, 2023 (Grand Chamber), *Deutsche Wohnen*, C-807/21, ECLI:EU:C:2023:950, paragraph 76 and *Nacionalinis visuomenės sveikatos centras*, C-683/21, ECLI:EU:C:2023:949, paragraph 81.

96 Statement of objections, paragraph 91.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

36/47

107.

In light of the above, the Restricted Formation is of the opinion that the facts and

failures observed do not reflect a deliberate intention to violate the GDPR on the part of the controlled entity. Nevertheless, it finds that the failures were committed through negligence.

108.

Regarding the categories of personal data concerned (Article 83.2.g) of the GDPR), the Restricted Formation holds that the recordings captured by the surveillance system do not fall under Articles 9 and 10 of the GDPR and therefore do not represent any particular sensitivity.

109.

Considering its assessment of the relevant criteria of Article 83.2.a), b), and g) of the GDPR above, the Restricted Formation believes that the classification of the severity of the violations should be considered as moderate.

2.1.2.3. The company's turnover

110.

To conclude step 2, the Restricted Formation takes into account the turnover of the controlled entity in accordance with the Guidelines on the calculation of fines. It notes that the net turnover of the controlled entity for the year 2022 amounted to EUR [company with a turnover between 2 and 10 million euros] with a net profit of EUR [...] according to the annual accounts for the year 2022, which the controlled entity submitted to the Restricted Formation by email on October 1, 2024. However, according to Article 83.5 of the GDPR, the Restricted Formation is supposed to take into account the turnover of the "previous financial year," that is, the financial year preceding the year of the decision issued by the authority, and thus for the year 2023. However, the controlled entity only sent a draft balance sheet showing a net turnover of EUR [company with a turnover between 2 and 10 million euros] by email on October 1, 2024.

2.1.3. Step 3: Assess aggravating and mitigating circumstances

111.

In accordance with the Guidelines on the calculation of fines, the supervisory authority must, thirdly, assess whether any aggravating or mitigating circumstances apply to the circumstances of the case. The guidelines specify that the supervisory authority must take each criterion provided for in Article 83.2 into account only once.

97 See Guidelines on the calculation of fines, Chapter 4.3, points 63 to 69.

98 Guidelines on the calculation of fines, point 131.

99 Guidelines on the calculation of fines, Chapter 5.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

37/47

Thus, after evaluating, in step 2, the nature, severity, and duration of the violation (Article 83.2.a) of the GDPR), as well as its deliberate or negligent character (Article 83.2.b) of the GDPR), and the categories of personal data concerned (Article 83.2.g) of the GDPR), the Restricted Formation will evaluate the other aggravating and mitigating circumstances under Article 83.2 of the GDPR (Article 83.2 points c), d), e), f), h), i), j), and k) of the GDPR). It will analyze only the relevant factors for the present case.

112.

Regarding the measures taken by the controlled entity to mitigate the damage suffered by the data subjects (Article 83.2.c) of the GDPR), the Restricted Formation notes, without prejudging the adequacy of the measures taken by the controlled entity, that the controlled entity sent on March 23, 2023 i) copies of the amendments to the employment contracts of its employees that contained certain information regarding the surveillance system and ii) a

photo of the new signage announcing the surveillance system at the entrance of Site A1. As for the other measures taken, particularly concerning the measures documented in the controlled entity's letter of June 21, 2024, these measures were implemented only after the notification of the grievances. These measures will be analyzed in Chapter II.2., Section 2.2. of this decision. In summary, it finds that all measures taken by the controlled entity were only implemented after the start of the investigation. Therefore, the Restricted Formation is of the opinion that these circumstances should be considered as neutral.

113.

Regarding the degree of responsibility of the data controller or the processor, considering the technical and organizational measures implemented under Articles 25 and 32 of the GDPR (Article 83.2.d) of the GDPR), the Restricted Formation refers to Chapter II.1. of this decision and more specifically to the failure related to the obligation and principle of accountability (Chapter II.1.D), the failure related to the principle of data retention limitation (Chapter II.1.E), and the failure related to the security of processing (Chapter II.1.F). It is of the opinion that the aforementioned failures already abundantly reflect that the controlled entity did not "do what could be expected of it [...] in light of the obligations incumbent upon it" and that, to avoid the factor of the degree of responsibility of the controlled entity being taken into account multiple times by the Restricted Formation, it is of the opinion that these circumstances should be considered as neutral.

100 Guidelines on the calculation of fines, points 70 to 72.

101 Guidelines on the calculation of fines, point 6.

102 Notification of grievances, Document No. 3 Annex 1.

103 Notification of grievances, Document No. 3 Annex 2.

104 Guidelines on the application and imposition of fines, page 14.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

38/47

114.

Regarding the degree of cooperation established with the CNPD, in order to remedy the violation and mitigate any potential negative effects (Article 83.2.f) of the GDPR), the Restricted Formation notes that, in light of the investigation file and, in particular, the responses provided by the controller during the investigation procedure, it should be concluded that the cooperation of the controller was good. However, it observes that the controller was subject to a general obligation of cooperation under Article 31 of the GDPR. Therefore, it is of the opinion that these circumstances should be considered neutral.

115.

As for any other aggravating or mitigating circumstances applicable to the circumstances of the case (Article 83.2.k) of the GDPR), the investigator noted "that the identified violations are not likely to bring any economic benefit to the Controller, that it is a small company without a legal advisor, that the activity of the Controller is unrelated to the field of data protection" and that "only a limited part of the processing (2 Cameras out of 10) is unlawful"¹⁰⁵. The Restricted Formation takes into account the aforementioned elements from the investigator and also the fact that the controller had been a victim of several burglaries in the past, which explains its increased need for surveillance. Therefore, it is of the opinion that these circumstances should be considered mitigating.

116.

The Restricted Formation finds that the other criteria of Article 83.2 of the GDPR are neither relevant nor likely to influence its decision regarding the imposition of an administrative fine and its amount.

117.

Therefore, considering the assessment of the relevant criteria of Article 83.2 of the GDPR, the

Restricted Formation considers that the imposition of an administrative fine is justified for the breaches identified under Articles 6.1, 5.1.a) related to Articles 13.1 and 13.2, 5.2 related to Article 24.1, 5.1.e) and 32.1 of the GDPR.

2.1.4. Step 4: Determine the applicable maximum legal amount

118.

In accordance with the Guidelines on the calculation of fines, the supervisory authority must, fourthly, determine the applicable maximum legal amounts¹⁰⁶. The guidelines remind that the GDPR does not assign fixed amounts to specific violations but that the GDPR provides for general maximum amounts. Therefore, it is necessary to ensure that these maximum amounts are not exceeded¹⁰⁷.

119.

To determine the correct maximum legal amount, Article 83.3 of the GDPR must be taken into consideration when it applies¹⁰⁸. In this case, the Restricted Formation considers that it is a single behavior (see point 91 of this decision) that has resulted in several violations of the GDPR arising from "the same processing operation or related processing operations"¹⁰⁹ and that these violations can be attributed together¹¹⁰. Therefore, it considers that Article 83.3 of the GDPR is applicable in this case and the administrative fine will be calculated taking into account all the violations, but the maximum legal amount will be capped at that of the most serious violation according to Article 83.3 of the GDPR¹¹¹.

120.

The Restricted Formation has already noted that the net turnover of the controller amounted to EUR [company with a turnover between 2 and 10 million euros] for the year 2022 and, according to a draft balance sheet, to EUR [company with a turnover between 2 and 10 million euros] for the year 2023 (see point 110 of this decision).

121.

The Restricted Formation notes that since several breaches attributed to the controller (notably the breaches of Articles 6.1, 5.1.a) related to Articles 13.1 and 13.2, 5.2 and 5.1.e) of the GDPR) are classified under the provision of Article 83.5 of the GDPR, the maximum amount of the fine that can be imposed is 20 million euros or 4% of the annual turnover of the company, "the higher amount being retained," in accordance with Article 83.5 of the GDPR. Therefore, the Formation holds that in this case the maximum amount of an administrative fine is 20 million euros¹¹².

122.

In this case, considering steps 1 to 4 of this decision (see points 89 to 122), and more particularly the number of breaches identified in this case, the classification of some of the breaches under Article 83.5 of the GDPR, their medium severity, as well as the turnover and net result of the controller and

¹⁰⁷ Guidelines on the calculation of fines, points 112 and 113.

¹⁰⁸ Guidelines on the calculation of fines, point 113.

¹⁰⁹ See Article 83.3 of the GDPR.

¹¹⁰ Guidelines on the calculation of fines, Chapter 3.1.2, points 38 to 45; See also the diagram on page 13 of the Guidelines on the calculation of fines.

¹¹¹ Guidelines on the calculation of fines, Chapter 3.1.2; See Diagram on page 13 of the Guidelines on the calculation of fines.

¹¹² According to the fixed range specified in point 114 of the Guidelines on the calculation of fines.

administrative fine to be imposed should amount to €2,300 (two thousand three hundred euros).

2.1.5. Step 5: Determine whether the final amount of the calculated fine is effective, proportionate, and deterrent

123. In accordance with the Guidelines on the calculation of fines, the supervisory authority must, fifthly, ensure that the administrative fine imposed for the GDPR violations referred to in Article 83.4 to 6 is, in each case, effective, proportionate, and deterrent, as required by Article 83.1 of the GDPR¹¹³. According to the EDPB, it is the responsibility of the supervisory authority to verify whether the amount of the fine imposed meets these requirements or whether other adjustments to the amount are necessary¹¹⁴.

124. The Restricted Formation considers that the amount of the fine appears to be both effective, proportionate, and deterrent, in accordance with the requirements of Article 83.1 of the GDPR.

2.2. Regarding the implementation of corrective measures

125. In the statement of objections, the head of the investigation also proposed to the Restricted Formation to adopt the following corrective measures (excluding the administrative fine):

a) "Regarding the violation of the principle obligation to determine a relevant legal basis, the head of the investigation considers that an order to limit the processing, within the meaning of Article 58.2 f) of the GDPR, would be the appropriate corrective measure. More specifically, the head of the investigation is of the opinion that the cameras lacking a legal basis, namely camera SPOT A CAM2 at site A1 and camera SPOT B CAM6 at site A2, must be removed and that any recordings made using said cameras must be permanently deleted."¹¹⁵

b) "Regarding the violation of the principle obligation to inform the data subjects arising from Article 5.1 (a) of the GDPR in conjunction with Articles 13.1 and 13.2 of the GDPR, the head of the investigation considers that an order for compliance with the processing, within the meaning of Article 58.2 d) of the GDPR, would be the appropriate corrective measure. More specifically, the head of the investigation is of the opinion that the Controlled entity must provide the data subjects affected by the Processing (employees on one hand, clients/suppliers on the other hand) with all the information set out in Articles 13.1 and 13.2 of the GDPR under the conditions provided in those articles. The head of the investigation also draws attention

113 Guidelines on the calculation of fines, Chapter 7.

114 Guidelines on the calculation of fines, point 132.

115 Statement of objections, point 83.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

41/47

of the Controlled regarding the fact that this information must be drafted in accordance with the provisions of Article 12.1 of the GDPR relating to the necessary transparency of the information to be provided to the data subjects.¹¹⁶

c) "As for the violation of the principle of accountability imposed on the Controlled and arising from Article 5.2 of the GDPR in conjunction with Article 24.1 of the GDPR, the head of the investigation considers that a reprimand, in the sense of Article 58.2 b) of the GDPR, would be the appropriate corrective measure, as the failure to comply with these obligations allowed the installation of cameras lacking a lawful basis. The attention of the Controlled is drawn to the importance of respecting the principle of accountability which, in this case, places the obligation on the Controlled to be able to demonstrate the lawfulness of the Processing."¹¹⁷

d) "As for the violation of the obligation to limit the retention of data arising from Article 25.2 of the GDPR, the head of the investigation considers that an order for compliance with the processing, in the sense of Article 58.2 d) of the GDPR, would be the appropriate corrective measure. More specifically, the head of the investigation is of the opinion that the retention period for personal data collected through the Video Surveillance Device must be reduced to 8 days."¹¹⁸

e) "[A]s for the violation of the obligation to implement appropriate technical and organizational measures arising from Article 32.1 of the GDPR, the head of the investigation considers that an order for compliance with the processing, in the sense of Article 58.2 d) of the GDPR, would be the appropriate corrective measure. More specifically, the head of the investigation is of the opinion that the Monitor must be secured through individualized user accounts and passwords in order to ensure the traceability of accesses and the association of actions, such as, for example, the deletion or modification of video recordings, to a clearly identifiable person. Furthermore, it will also be necessary to physically secure access to the software that processes personal data and the viewing of such data in order to prevent any access or viewing by an employee who is not one of the three authorized employees, for example by programming an automatic lock of the Monitor after a short period of inactivity."¹¹⁹

126.

Regarding the corrective measures proposed by the head of the investigation and by reference to point 84 of this decision, the Restricted Formation takes into account the steps taken by the Controlled to comply with the provisions of the GDPR, as detailed in its letters of March 23, 2023, May 2, 2023, June 21, 2024, and October 1, 2024. More specifically, it takes note of the following facts:

116 Statement of objections, point 84.

117 Statement of objections, point 85.

118 Statement of objections, point 86.

119 Statement of objections, point 87.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

42/47

127.

Regarding the order to limit processing (cf. point 125 under a) of this decision) proposed by the head of the investigation under Article 58.2.f) of the GDPR for the breach related to the principle of lawfulness (Article 6.1 of the GDPR), the Restricted Formation notes that the controller has, firstly, contested in its letter dated June 21, 2024, the head of the investigation's opinion that the legal basis of consent under Article 6.1.a) was "ineffective"¹²⁰. According to the controller, the legal basis of consent is valid and to demonstrate that the employees of the controller are not only consenting but especially requesting the video surveillance system, it has sent testimonial attestations signed by each of its employees in which the employees responded to the question "What do we think of the cameras?"¹²¹. Secondly, the controller also contested that the legal basis of compliance with a legal obligation (in this case, the employer's obligation to ensure the safety of its employees as provided for in Article L.312-1 of the Labor Code) could not apply (as held by the head of the investigation¹²²). According to him, "video surveillance is the only means to ensure a minimum level of security"¹²³. Thirdly, he believes that there is a third legal basis which consists of "the protection of property" as the controller sold and recycled "computer equipment ([...] ...) highly sought after and electronic components of high added value. However, this type of business is very regularly the victim of violent attacks."¹²⁴. He also adds that, in his opinion, "the positioning of the cameras only provides a partial view of the employees, even if there is continuous monitoring, the employee is not filmed continuously (with the exception of the chair of the manager [...] and the workstation of an employee who would have expressly requested that their work be filmed)." He also explained that his employees would "have the possibility to regularly evade the surveillance points" (for example, "to smoke cigarettes together at the back of the building"). According to the controller, employees would therefore not be filmed continuously and there would be no psychological pressure. It also emerges from his position in response to the communication of grievances that he believes that camera no. 1 and camera no. 2 would be important cameras but that he would have taken measures to comply with the GDPR by masking "with a black square, the faces of the employees, so that the camera only films their hands and their

workstation"¹²⁵.

120 Communication of grievances, point 46, first bullet.

121 Letter from the controller dated June 21, 2024, Annexes 1 and 2.

122 Communication of grievances, point 28.

123 Letter from the controller dated June 21, 2024, point D) 1) i), page 6.

124 Letter from the controller dated June 21, 2024, point D) 1) i), page 6.

125 Letter from the controller dated June 21, 2024, point D) 1) iii), page 9 and its Annex 4.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

43/47

The Restricted Formation notes that the controller, by letter dated June 11, 2024, sent photos to demonstrate that he has limited the fields of vision of camera no. 1 and camera no. 2 so that the faces of the concerned employees are no longer visible. Nevertheless, it finds that the two disputed cameras still lack a legal basis and are therefore unlawful (see points 34 to 38 of this decision for further explanations). It also notes that in the new guide on the management of personal data provided by the controller in the same letter (hereinafter: the "new guide")¹²⁶, the controller has still not mentioned the applicable legal basis or bases according to Article 6.1 of the GDPR to justify the lawfulness of the video surveillance system. As outlined in points 34 to 38 of this decision, it considers that the legal basis of legitimate interest provided for in Article 6.1(f) would be the most appropriate legal basis to justify the video surveillance system (with the exception of cameras no. 1 and no. 2).

In light of the insufficient compliance measures taken by the controller in this case, the Restricted Formation therefore considers that it is appropriate to impose the corrective measure proposed by the head of investigation in this regard and reiterated in point 125 of this decision under a).

128.

Regarding the order for compliance with the processing (see point 125 under b) of this decision) proposed by the head of investigation pursuant to Article 58.2(d) of the GDPR for the breach related to the principle of transparency and information obligations (Article 5.1(a) related to Articles 13.1 and 13.2 of the GDPR), the Restricted Formation notes that the controller, in his response to the statement of objections, sent the new guide and a copy of a new display board (hereinafter: the "new display board"). He mentioned that the new display board also contained a direct reference to an information page on the controller's website containing the new guide but that this QR code would only be functional "in the coming days"¹²⁷. During the session on September 18, 2024, the Restricted Formation invited the controller to send, within 2 weeks, the current version of the new display board with the functional QR code and also wanted to know on which site this new display board was exactly displayed. The controller responded during this session that the new display board was displayed only at the entrance door of Site A1 and that he had indeed forgotten to display it at Site A2. By letter dated October 1, 2024, the controller sent, on the one hand, the current versions of the new display board and the new guide, and, on the other hand, photos showing that the current version of the display board has now been displayed at the entrance doors of Site A1 and Site A2.

The Restricted Formation finds that the current version of the new display board now contains the first-level information including the reference to the more detailed second-level information (providing a QR code and the possibility of receiving the new guide at the cash registers of the controller's stores) and that this first level of information is therefore accessible to employees as well as third parties from the entrance of Site A1 and Site A2.

Regarding the second level of information, it finds that the current version of the new guide now contains most of the required information within the meaning of Articles 13.1 and 13.2 of the GDPR. However, it finds that neither the new guide sent on June 21, 2024, nor the current version of the new guide sent on October 1, 2024, contains one of the legal bases exhaustively listed in Article 6.1 of the

GDPR. The first point of the current version of the new guide only mentions the purposes pursued by the controller through the implementation of the video surveillance system. Therefore, it is still unclear on what legal basis the said system is based.

In light of the insufficient compliance measures taken by the controller in this case, the Restricted Formation therefore considers that it is appropriate to impose the corrective measure proposed by the head of investigation in this regard and reiterated in point 125 of this decision under b).

129.

Regarding the reprimand (see point 125 under c) of this decision) proposed by the head of investigation pursuant to Article 58.2(b) of the GDPR for the breach related to the principle and obligation of accountability (Article 5.2 related to Article 24.1 of the GDPR), the Restricted Formation notes that the controller has now established documentation that can, for the most part, prove compliance of the video surveillance system. Nevertheless, and as already raised in point 127 above, there is still a lack of one or more legal bases exhaustively listed in Article 6.1 of the GDPR.

In light of the compliance measures taken by the controller in this case, the Restricted Formation therefore considers that there is no need to impose the corrective measure proposed by the head of investigation in this regard and reiterated in point 125 of this decision under c).

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

44/47

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

45/47

130.

Regarding the order for compliance with processing (see point 125 under d) of this decision) proposed by the head of the investigation pursuant to Article 58.2 d) of the GDPR for the breach related to the principle of data retention limitation (Article 5.1.e) of the GDPR), the Restricted Formation notes that the new guide mentions a maximum data retention period of 8 days for recordings made by the video surveillance system, except in exceptional situations (for example, due to a burglary) where a maximum retention period of 30 days would be exceptionally permitted. It also notes that the controller has stated in its new guide that, once the period has passed, the recordings will be automatically deleted from the computer servers. In consideration of the sufficient compliance measures taken by the controller in this case, the Restricted Formation therefore considers that there is no need to impose the corrective measure proposed by the head of the investigation in this regard, as reiterated in point 125 of this decision under d).

131.

Regarding the order for compliance with processing (see point 125 under e) of this decision) proposed by the head of the investigation pursuant to Article 58.2 d) of the GDPR for the breach related to processing security (Article 32.1 of the GDPR), the Restricted Formation notes, on the one hand, that the controller confirmed in its letter dated June 21, 2024, that monitor A1 (accessible in a non-lockable office) would now be secured through user accounts and individualized passwords. According to it, only three authorized persons would each have an individual user account for the software. On the other hand, it notes that the controller has stated that the activation duration of the said monitoring device has been modified so that, after 3 minutes of inactivity, the screen would automatically lock. The Restricted Formation notes that the controller has also secured access (physical) to the software to prevent any

access or viewing by an employee who is not one of the three authorized persons holding an individual user account.

In consideration of the sufficient compliance measures taken by the controller in this case, the Restricted Formation therefore considers that there is no need to impose the corrective measure proposed by the head of the investigation in this regard, as reiterated in point 125 of this decision under e).

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

46/47

In light of the preceding developments, the National Commission sitting in a restricted formation, after deliberation, decides:

- to uphold the breaches of Articles 6.1, 5.1.a) related to Articles 13.1 and 13.2, 5.2 related to Article 24.1, 5.1.e) and 32.1 of the GDPR;

- to impose the following corrective measures against the company "A":
 -

- an order to limit processing within the meaning of Article 58.2 f) of the GDPR concerning cameras no. 1 (named "SPOT A CAM2" at Site A1) and no. 2 (named "SPOT B CAM6" at Site A2) for the breach of Article 6.1 of the GDPR and, more specifically, that the two aforementioned cameras must be removed and that any recordings made using the disputed cameras must be permanently deleted;

- an order for compliance with processing within the meaning of Article 58.2.d) of the GDPR for the breach of Article 5.1.a) related to Articles 13.1 and 13.2 of the GDPR and, more specifically, that the new "data management guide" of the controller be supplemented by one or more legal bases provided for in Article 6.1 of the GDPR on which the video surveillance system is based;

- to impose an administrative fine of two thousand three hundred (2,300) euros against the company "A" in light of the breaches of Articles 6.1, 5.1.a) related to Articles 13.1 and 13.2, 5.2 related to Article 24.1, 5.1.e) and 32.1 of the GDPR.

Belvaux, November 20, 2024.

The National Commission for Data Protection sitting in a restricted formation

Tine A. Larsen Thierry Lallemand

Marc Lemmer

President

Commissioner

Commissioner

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

47/47

Indication of appeal avenues

This administrative decision may be subject to an appeal for reform within three months following its notification. This appeal must be brought before the administrative court and must necessarily be filed through a lawyer at the Court of one of the Bar Associations.